Project Report

- ## Introduction to VAPT

Vulnerability Assessment and Penetration Testing (VAPT) is a cybersecurity process used to identify, evaluate, and validate security weaknesses in systems, networks, and applications.

- ## Tools used

- **DVWA**
  Damn Vulnerable Web Application is an intentionally insecure web application used for learning web application security testing.

- **XAMPP**
  XAMPP is a local development environment that includes components such as Apache, MariaDB, PHP, and Perl.
  Apache serves the web application, PHP executes application code, and the database stores application data.

- **Burp Suite Community Edition**
  Burp Suite is a web application security testing tool. Its proxy functionality allows a tester to inspect HTTP requests and responses between a browser and a web application.

- **OWASP ZAP**
  OWASP Zed Attack Proxy (ZAP) is an open-source web application security testing tool.

- **Kali Linux**
  Kali Linux is a Linux distribution designed for penetration testing and security assessments. It provides a platform for running security tools, including OWASP ZAP.

- ## Testing process

SQL Injection Test -

Testing Procedure

1. Open DVWA and log in.
2. Navigate to the SQL Injection module.
3. Enter a normal test value and record the expected result.
4. Enter a controlled SQL Injection test input.
5. Submit the input.

6. Compare the response with the normal request.
7. Capture the relevant request and response in Burp Suite.
8. Record the actual output and evidence.

Cross-Site Scripting Testing

Testing Procedure:

1. Open the Stored XSS module.
2. Submit a normal test value first.
3. In the authorized lab, enter the same harmless proof-of-concept if the module permits it.
4. Submit the input.
5. Reload or revisit the page.
6. Observe whether the content persists and executes.
7. Capture the submission and subsequent page response.

OWASP ZAP Automated Scan

Testing Procedure:

1. Launch OWASP ZAP in Kali Linux.
2. Select Quick Start.
3. Open Automated Scan.
4. Enter the DVWA URL.
5. Click Attack.
6. Allow ZAP to discover and test accessible pages.
7. Review the Alerts tab.
8. Inspect alert evidence and risk levels.
9. Export the results in HTML format.

- **Findings & Risk Levels**

We were able to find alerts using ZAP.
Risk level was high, medium and low

- **Mitigation methods**

SQL Injection Mitigation

Recommended controls:

1. Use prepared statements and parameterized queries.
2. Avoid concatenating untrusted input into SQL commands.

XSS Mitigation
Recommended controls:

1. Use context-aware output encoding.
2. Use safe templating and DOM methods.

Authentication Mitigation
Recommended controls include:

- Secure password hashing.
- Appropriate multi-factor authentication.